PRÁCTICA 2 - CERTIFICADOS

Realizado por Unai García Blanco y Alberto García Martín

1. Obtención de certificados X.509 vía web

Para la realización de la práctica usaremos como Autoridad de Certificación (AC) http://www.CAcert.org

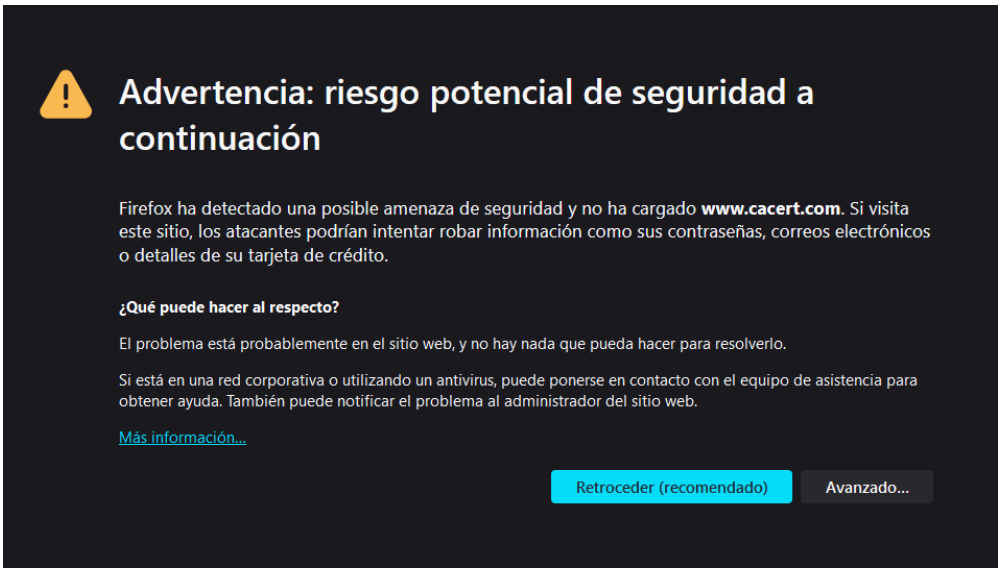
Acceder a la página http://www.cacert.org descargar e instalar el certificado raíz en nuestro navegador. Comprobar que una vez instalado ya no recibimos advertencia alguna de seguridad.

Adicionalmente, localizaremos el certificado en el almacén de certificados (pestaña Entidades emisoras raíz de confianza) de IE y trataremos de:

- **Comprobar para qué propósitos sirve (en propiedades)**
- **Editar las propiedades y modificar algún propósito de uso**
- **Anular la confianza en esta CA para identificar sitios web (servidores)**
- **Volver a acceder a la página de CAcert en modo https**
- **Restaurar las propiedades originales**

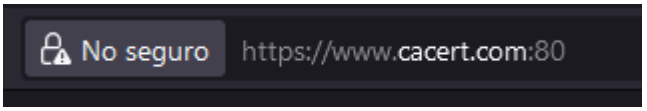
¿Se ve igual en distintos navegadores/almacenes?

Si desde un inicio intentamos acceder a la página indicando: https://www.cacert.com aparece lo siguiente:

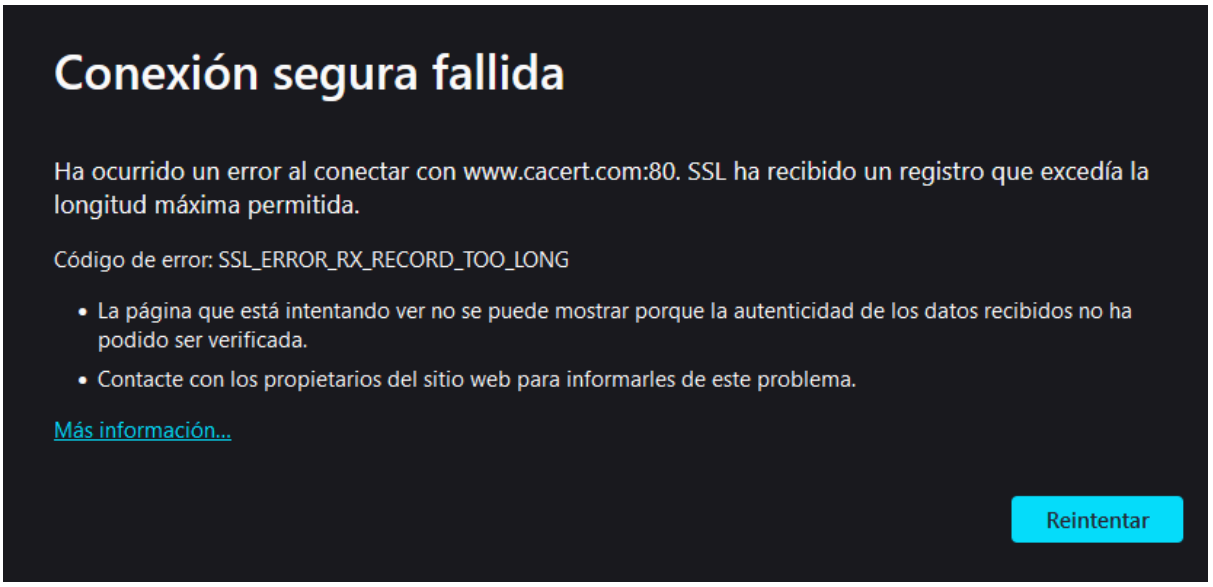


Por la manera en la que está configurado el equipo nos indica que la página no es segura,

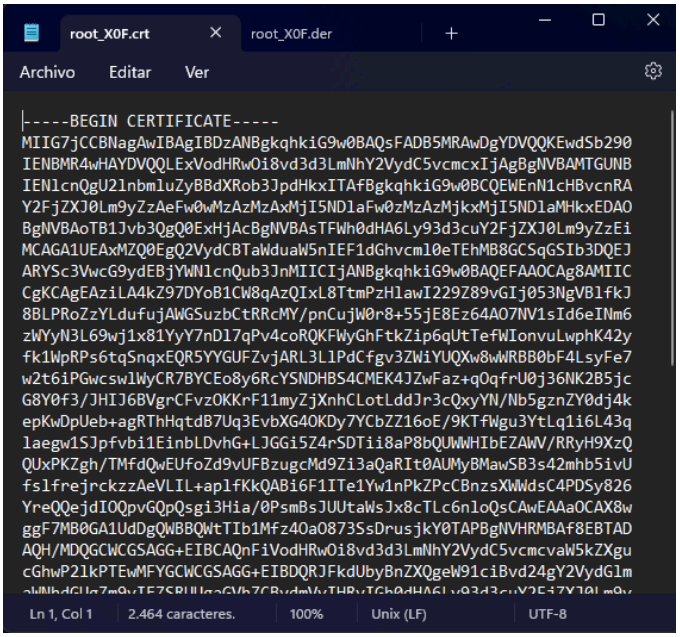
pero eso se puede configurar.
A la hora de buscar se puede indicar también el número de puerto seguro, que es el 80:



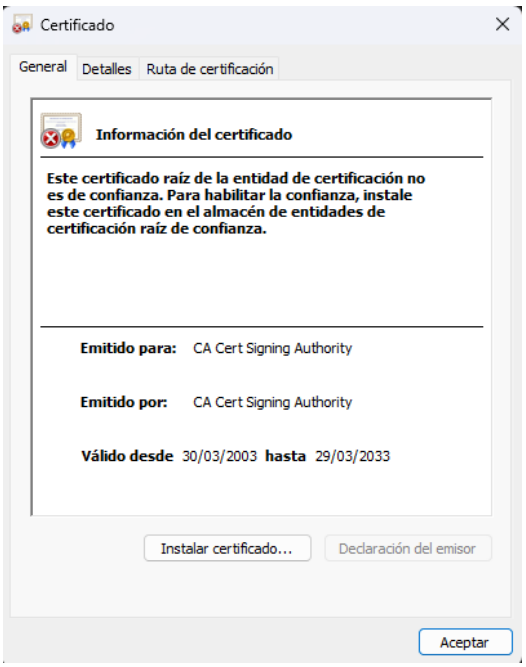
Pero sigue sin ser una conexión segura:



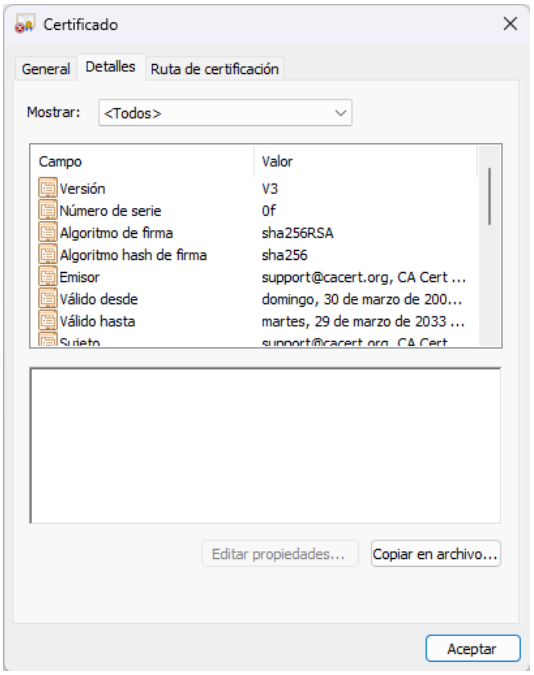
Ahora entraremos en CAcert y nos descargaremos su certificado raíz. Para ello, deberemos registrarnos. Posteriormente, y una vez descargado el certificado, si lo visualizamos en un editor de texto, observaremos lo siguiente:



Si empleamos la aplicación de windows para abrir e importar certificados veremos lo siguiente:



Se puede ver que el certificado es autofirmado porque los 2 campos de emitido son iguales.

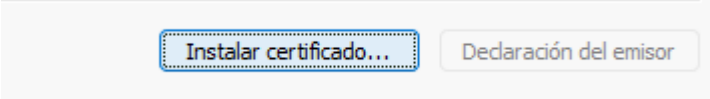


También se puede ver que el certificado ha sido firmado con el hashing del algoritmo RSA.

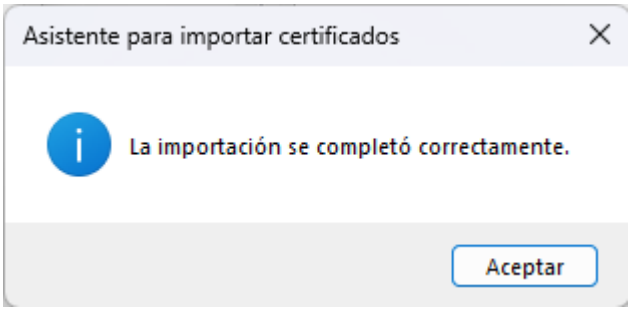


Y que el Root CA indica que se trata de un certificado raíz.

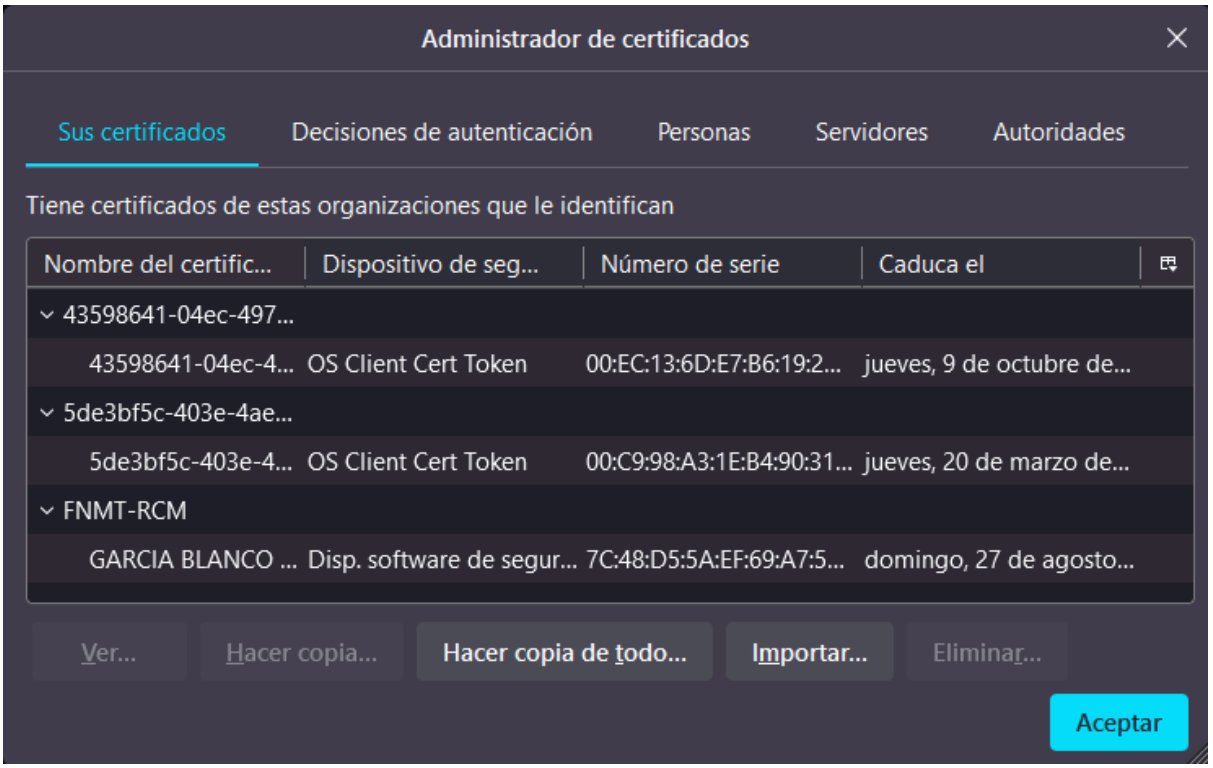
Se puede instalar en el almacén de certificados del sistema pulsando en “Instalar certificado” como se puede ver en ls siguiente imagen:



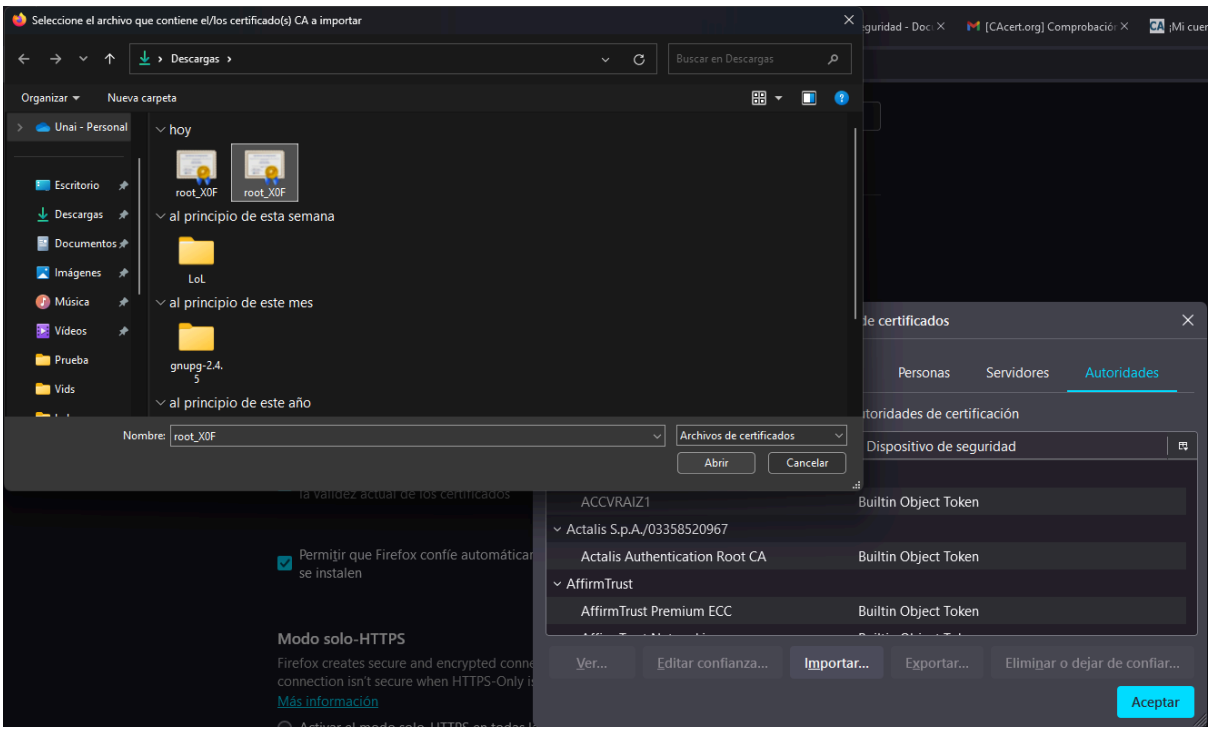
Tras seguir los pasos indicados, nos saldrá un mensaje de que todo ha salido bien y ya tendremos nuestro certificado importado.



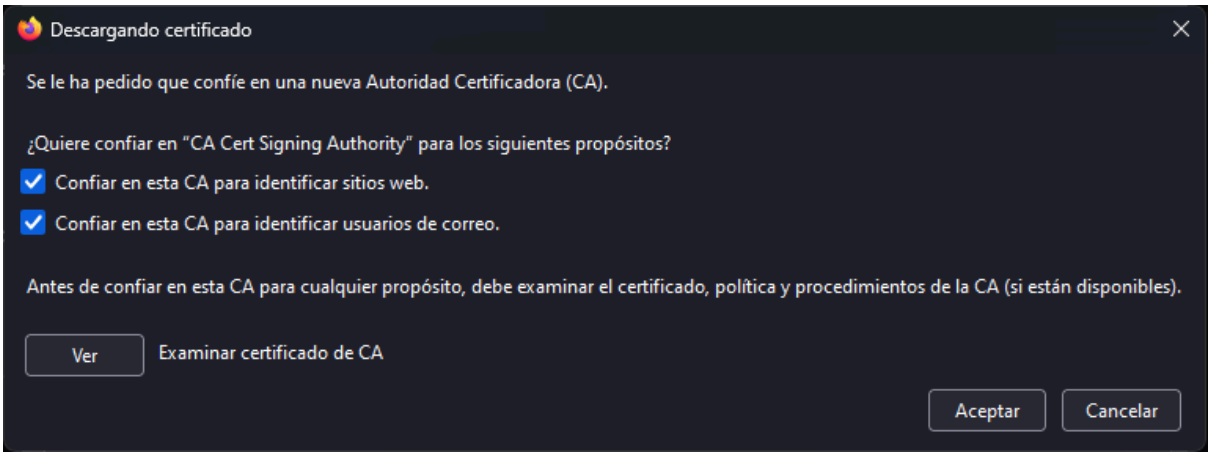
Para instalarlo en un navegador (en nuestro caso Firefox) iremos a Ajustes > Privacidad y Seguridad > Certificados > Ver certificados y nos saldrán los certificados instalados en nuestro navegador:



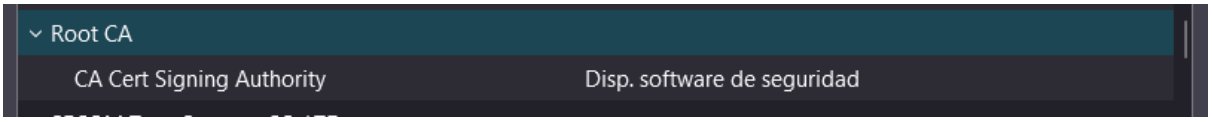
Y se importará en la parte de autoridades:



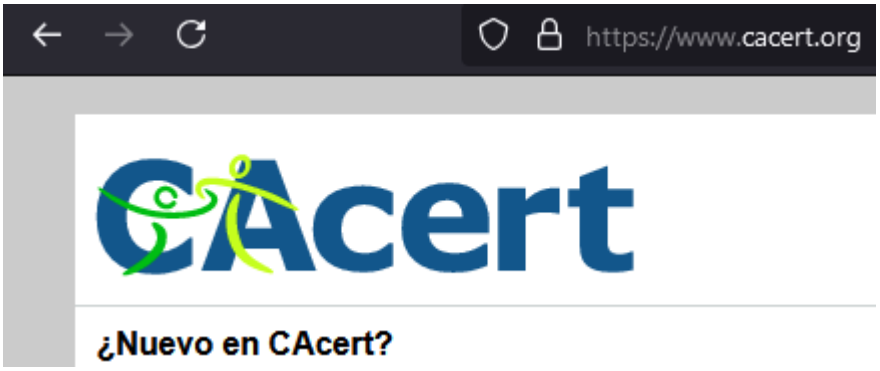
Y ahora terminaremos de importarlo:



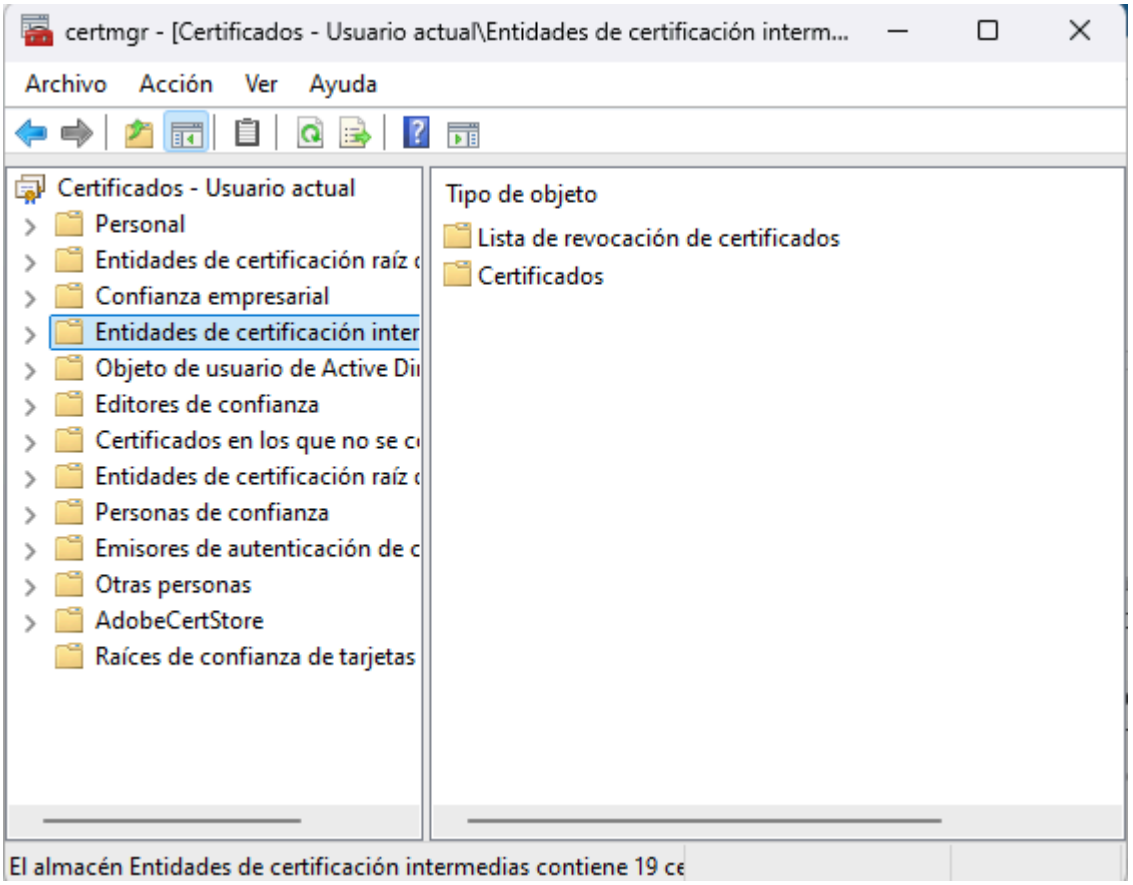
Y aquí podemos comprobar como se ha importado correctamente:



Tras instalarlo y acceder a la página con https, la página ya será segura:



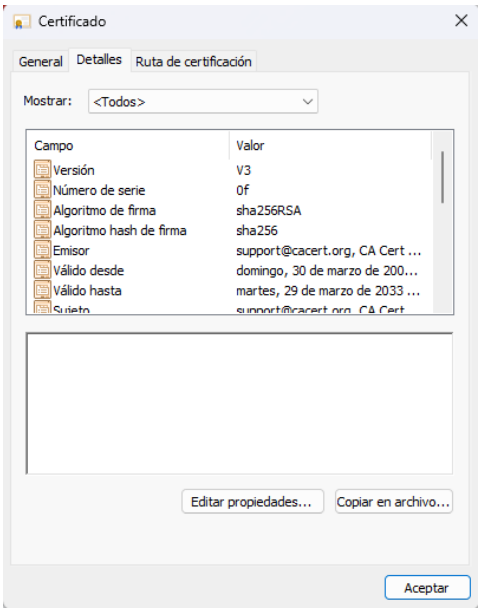
Certmgr.msc es la aplicación nativa de Windows para gestionar los certificados, se puede acceder a esta escribiendo “certificados” en la barra de búsqueda de windows.



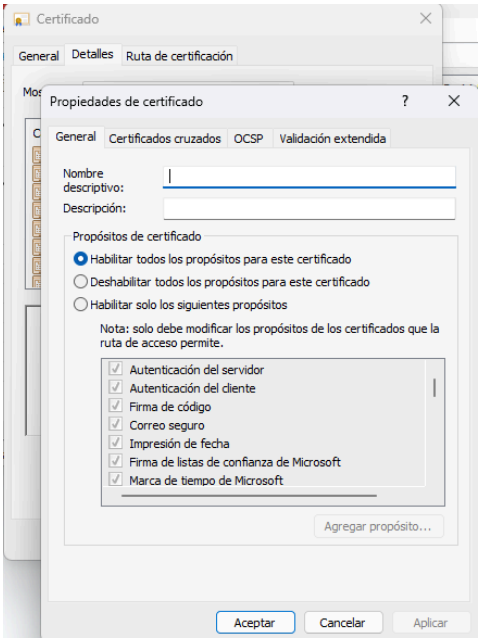
Vamos a visualizar los **propósitos del certificado**, para ello, se accede a los ajustes y una vez dentro -> Privacidad y seguridad-> Gestionar los certificados del dispositivo -> Se selecciona el de CAcert-> Detalles:



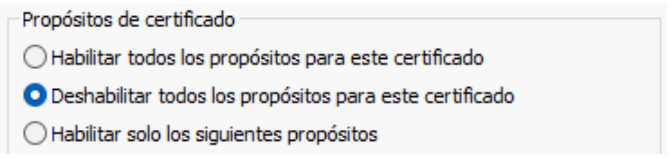
El mismo certificado que vimos anteriormente pero esta vez aparece sin la x, indicando que está añadido al almacén del sistema.



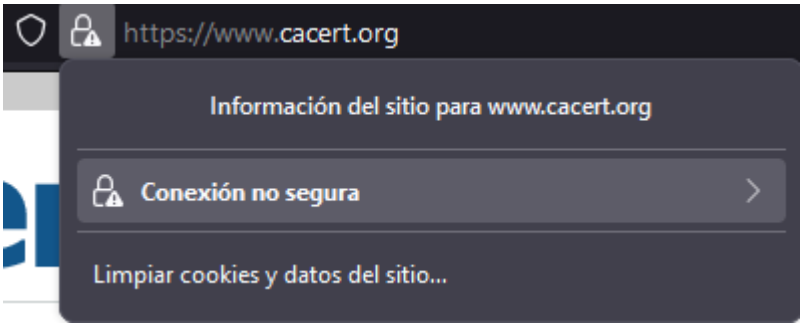
Se puede pulsar en Editar propiedades para continuar con la configuración.



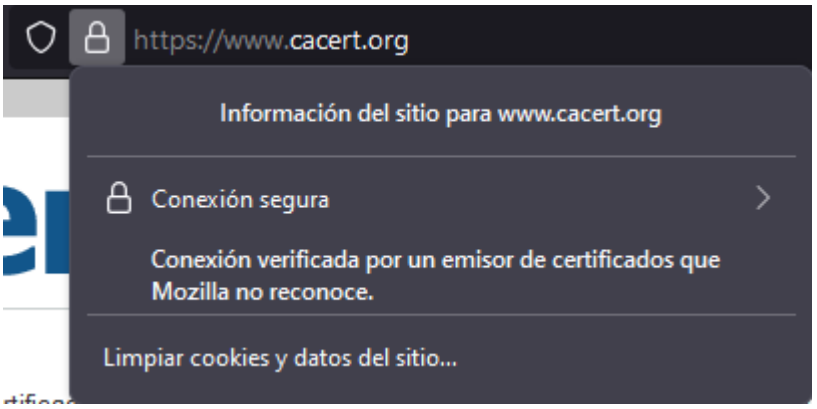
Podemos ver que tiene todos los propósitos habilitados. Esto es algo que nos permite modificar.
Probamos a marcar la opción de Deshabilitar todos los propósitos para este certificado:



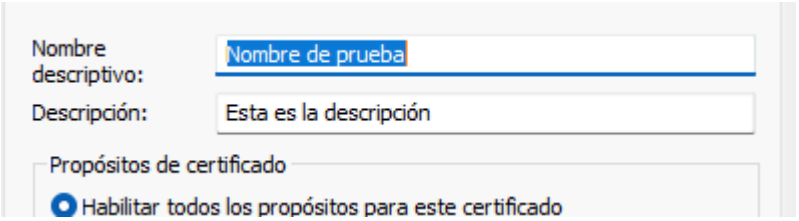
Y tras borrar los datos y la caché de chrome: Configuración > Privacidad y seguridad > Borrar datos de navegación > Configuración avanzada y reiniciar chrome, se puede ver que ya no reconoce el certificado como válido:



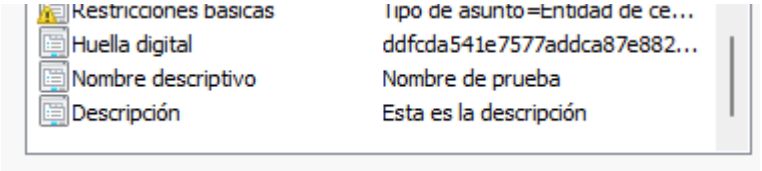
Si volvemos a marcar la opción anterior y a reiniciar chrome aparece como seguro otra vez:



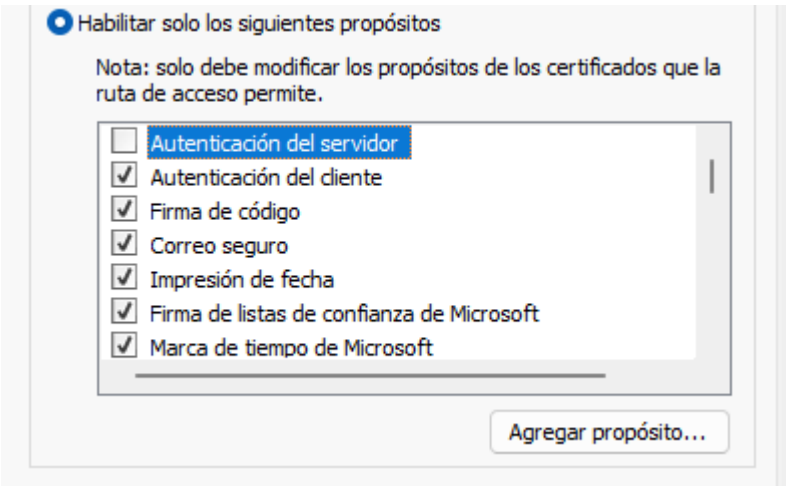
Se puede modificar también el nombre y la descripción:

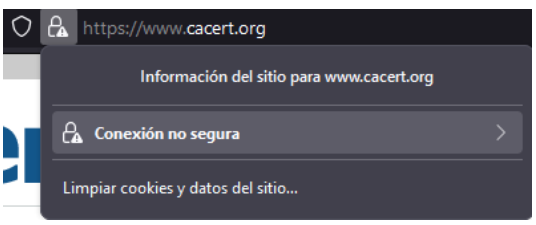


Visualizandose luego de la siguiente manera.



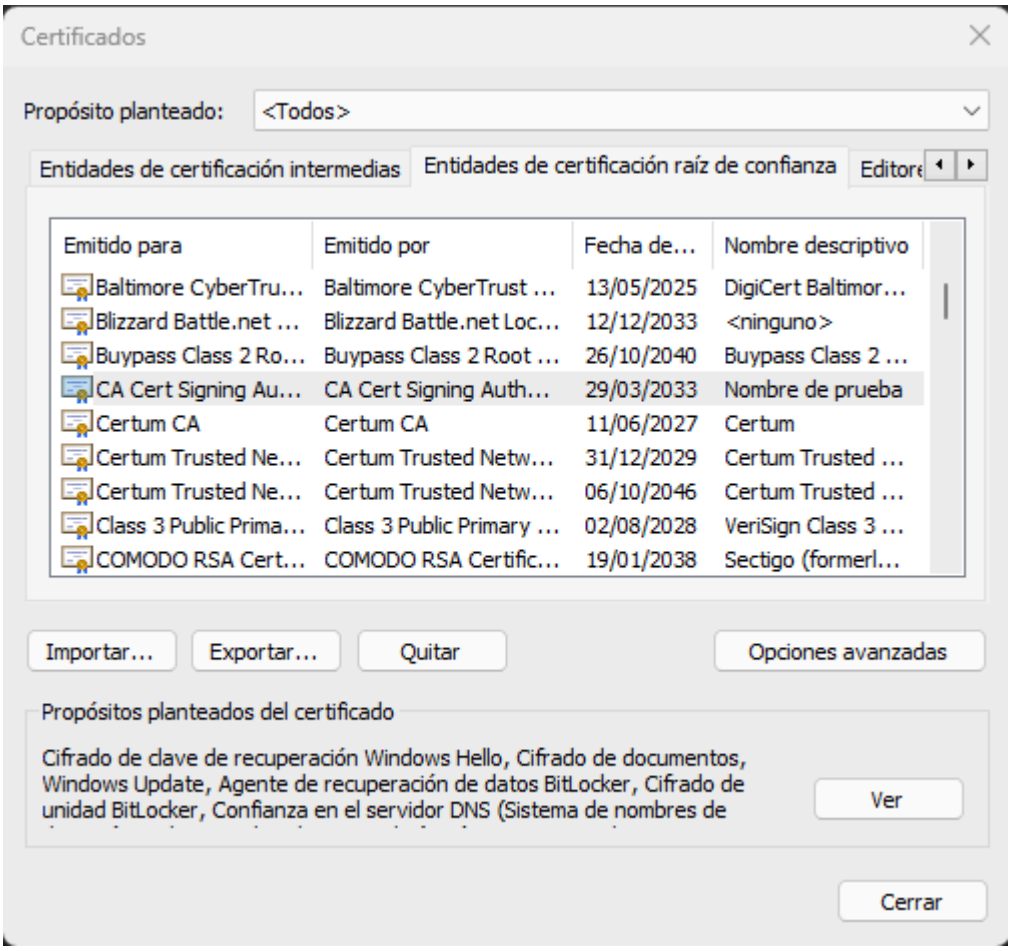
También se pueden modificar las casillas en opciones avanzadas:



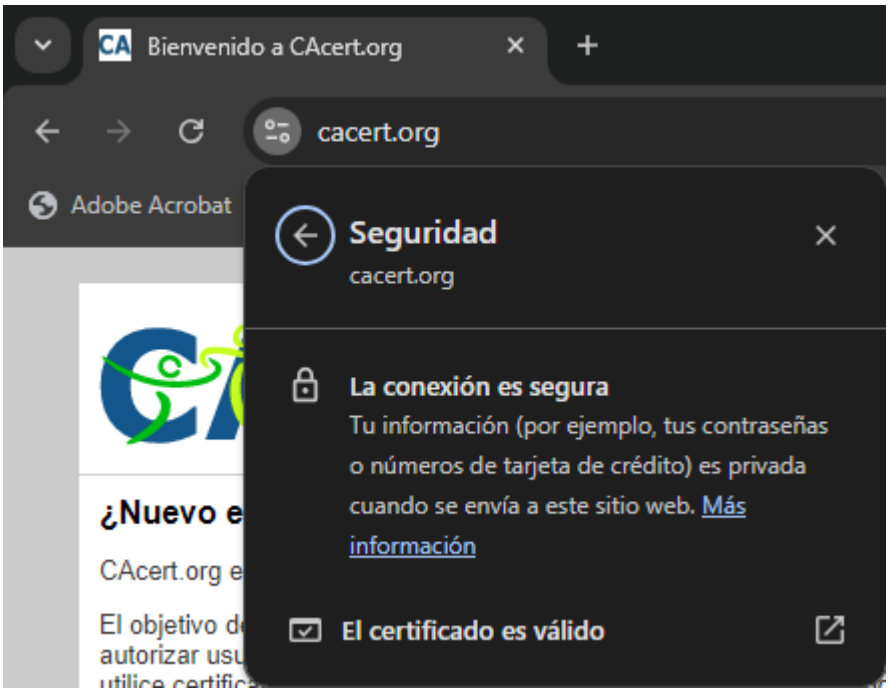


Si se desmarca la primera opción no debería aparecer como segura al recargar la página. Y así es.

En el caso de Google Chrome (por probar en otro navegador) al usar el mismo almacén de certificados de autenticación que el propio equipo, no es necesario importar el certificado ya que nos aparece automáticamente:



Y esto hará que la conexión sea segura a la web de CAcert desde el principio (si se ha instalado en el equipo con anterioridad, obviamente)



2. Solicitar un certificado digital personal (usuario)

Para que una AC pueda asegurar la identidad digital del sujeto y firmar un certificado personal hay que seguir un proceso para que la entidad emisora pueda verificar la información que contenga el certificado. Cada Autoridad procede de una manera. En el caso de los certificados emitidos por la Fábrica Nacional de Moneda y Timbre (FNMT) se valida el nombre y el NIF (campo CN del subject), pero no se verifica la dirección de correo electrónico (campo E del subject). En el caso de CAcert no verifica el nombre pero sí la dirección de correo electrónico. Para ello hay que hacer uso de peticiones estándar CSR (Certificate Signing Request).

Obtener e instalar en nuestro navegador un certificado personal de la autoridad CAcert (solo funciona en FireFox).

Comprobar que el certificado se ha instalado correctamente en el almacén de certificados de manera análoga a cómo comprobamos la instalación del certificado de la autoridad de Certificación. Verificar sus campos. Crear copia de seguridad del certificado que contiene el par de claves pública y privada (formato pk12) y el que contiene únicamente la clave pública (formato crt).

Acceder al sitio CAcert desde el navegador CHROME validando la identidad con certificado personal, no mediante usuario y contraseña.

Visualizar la información de los certificados de sitio mediante la herramienta openssl y con visores de certificados de interfaz gráfica.

Para empezar, obtendremos e instalaremos en nuestro navegador un certificado personal de autoridad CAcert. Para generar un CSR utilizaremos OpenSSL, que nos permitirá generar un par de claves pública y privada y crear la solicitud de firma.

Generamos, por tanto, un par de claves con el comando:

openssl genrsa -out private.key 2048

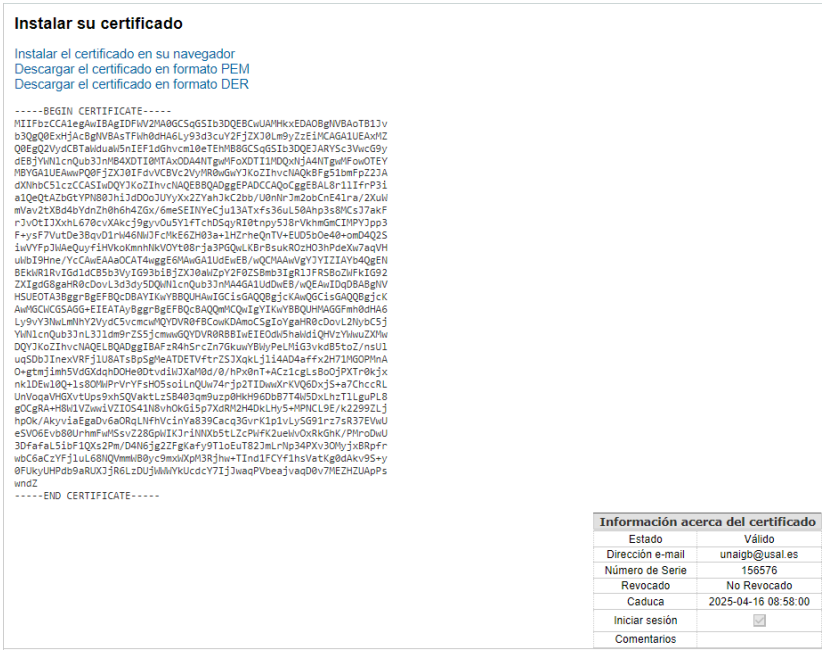
```
C:\Users\alber\openssl\bin>openssl genrsa -out beeto.key 2048
Loading 'screen' into random state - done
Generating RSA private key, 2048 bit long modulus
.....................................................................................................
.....................+++
.........+++
e is 65537 (0x10001)
```

Posteriormente, generamos el CSR con la clave privada con el comando:

openssl req -new -key private.key -out request.csr -config C:\Users\unaig\Desktop\SSI\openssl\share\openssl.txt

```
C:\Users\unaig>openssl req -new -key unai.key -out pet_unai.csr -config C:\Users\unaig\Desktop\SSI\openssl\share\openssl
.cnf -subj "/C=ES/ST=CyL/L=Salamanca/O=USAL/OU=SSI/CN=Unai XXXX/emailAddress=unaigb@usal.es" -passin pass:Spidey@MG7
Loading 'screen' into random state - done
```

Ahora solicitaremos una cuenta en CAcert y realizaremos la subida de nuestro archivo CSR. Para solicitarla, pegaremos nuestro archivo request.csr e instalaremos el certificado en nuestro navegador.

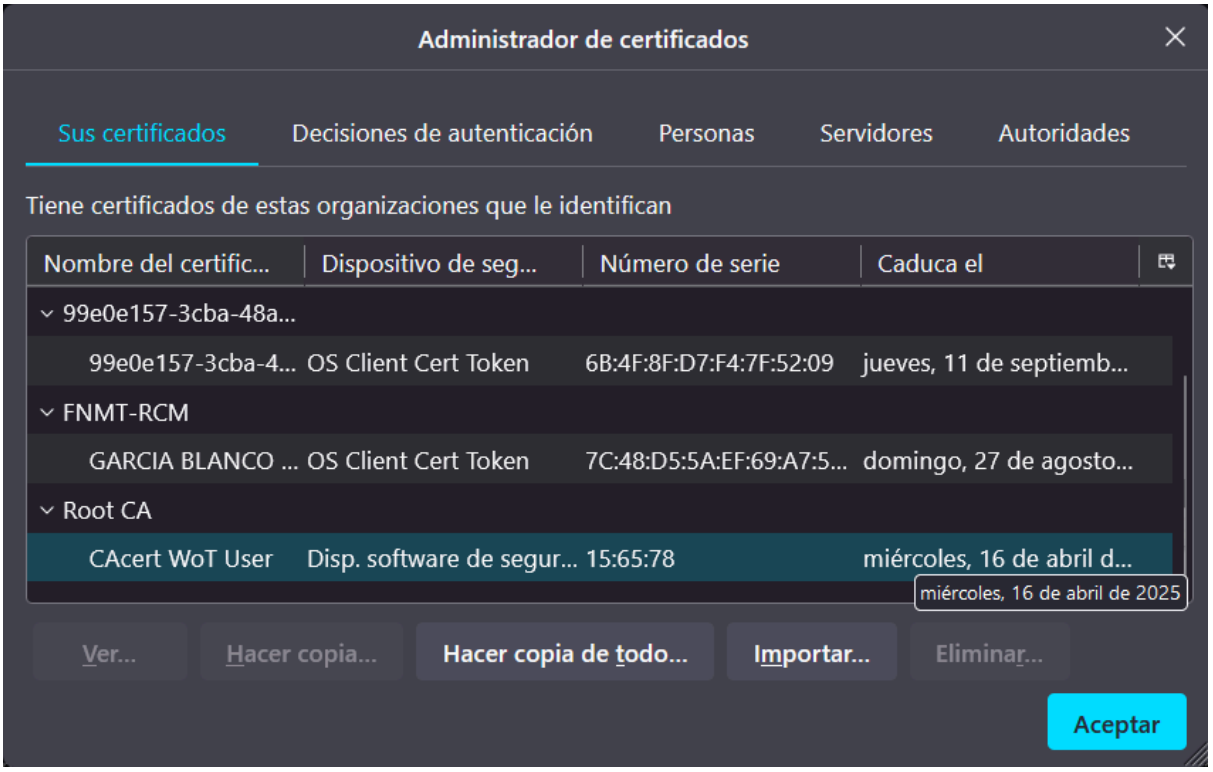


Descargamos desde el segundo enlace (Descargar el certificado en formato PEM) y nos generará el archivo “email@correo.com” en nuestro caso es “unaigb@usal.es” o “beetogm@usal.es”

Ahora introducimos el comando correspondiente y nos pedirá una contraseña que nos servirá en la importación a Firefox por ejemplo:

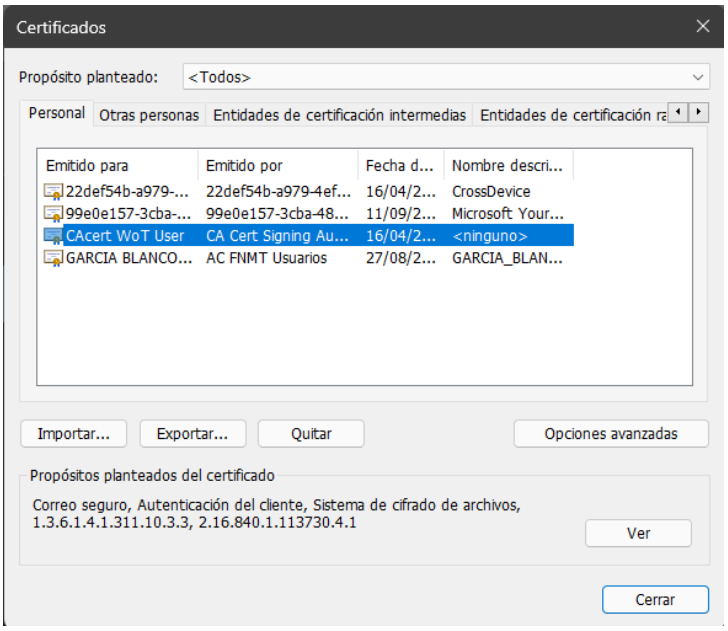
```
C:\Users\unaig\Desktop\SSI\openssl\bin>openssl pkcs12 -export -in C:\Users\unaig\Downloads\unaigb@usal.es.crt -inkey C:\
Users\unaig\unai.key -out C:\Users\unaig\unaiPrivada.p12
Loading 'screen' into random state - done
Enter Export Password:
Verifying - Enter Export Password:
```

Para comprobar el certificado, nos dirigimos a Ajustes/Privacidad y Seguridad/Certificados en nuestro navegador firefox. Seleccionamos la pestaña “ver certificados” y nos dirigimos al apartado sus certificados. Podremos importar nuestro certificado introduciendo la misma contraseña que anteriormente.



En el caso del almacén de certificados, como firefox actualmente ya cuenta con almacén propio, si vamos a comprobar la instalación en el almacén de nuestro equipo, veremos que no se encuentra ahí, ya que no es el mismo almacén.

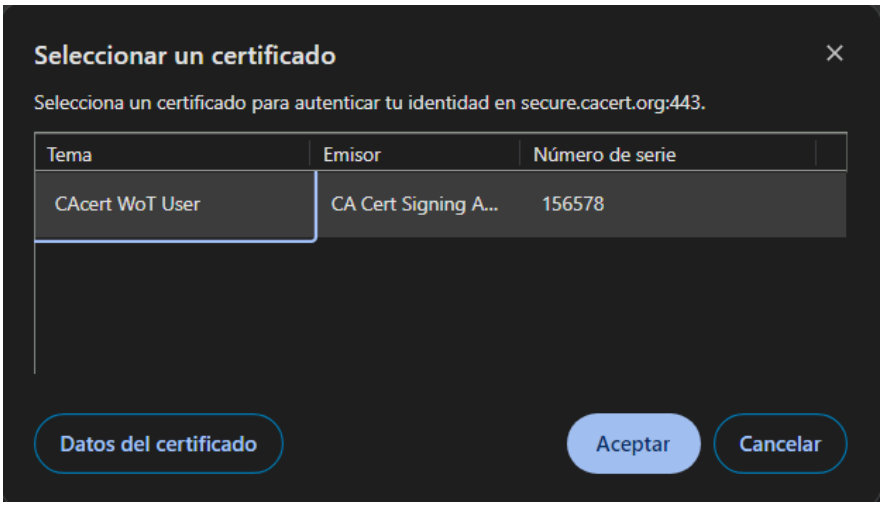
Como vimos en el apartado 1, Chrome si que compartía el almacén de certificados con el de Windows, o más bien los importaba automáticamente, por lo que nosotros hemos instalado en el equipo el certificado personal obtenido, y efectivamente Chrome lo reconocía.



Por lo que ahora podremos iniciar sesión con certificado:



Nos pedirá seleccionar el certificado en caso de tener más de uno:



Y ya tendremos la sesión iniciada mediante certificado:



Para visualizar la información de los certificados de sitio mediante la herramienta openssl y con visores de certificados de interfaz gráfica, haremos lo siguiente:

En el caso de openssl, si usamos el siguiente comando:

```
C:\Users\unaig>openssl s_client -connect www.cacert.org:443 | openssl x509 -text
```

Y obtendremos los resultados por consola de la siguiente manera:

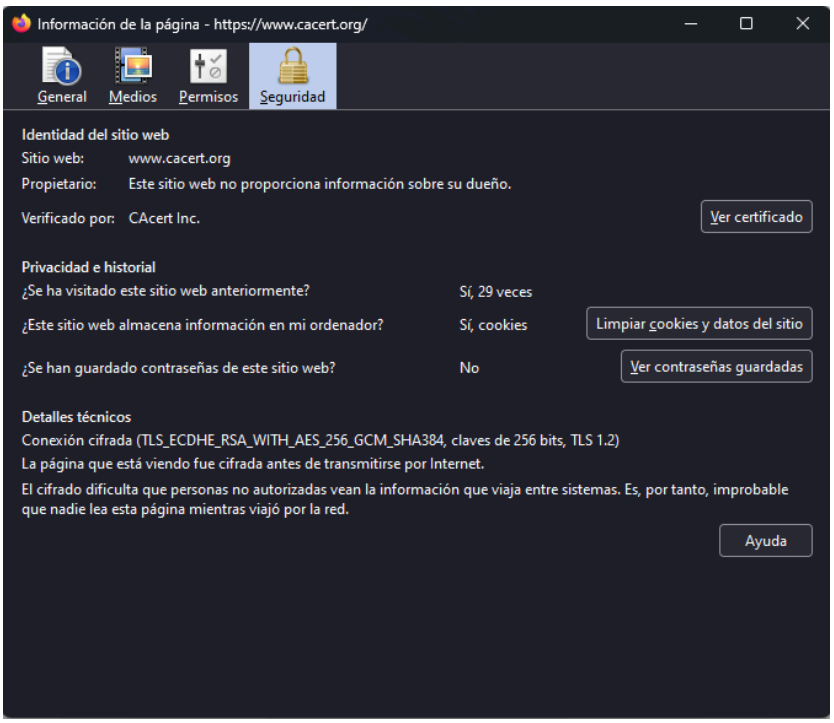
```
Loading 'screen' into random state - done
depth=2 /O=Root CA/OU=http://www.cacert.org/CN=CA Cert Signing Authority/emailAddress=support@cacert.org
verify error:num=19:self signed certificate in certificate chain
verify return:0
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number: 197831 (0x304c7)
        Signature Algorithm: sha512WithRSAEncryption
        Issuer: O=CAcert Inc., OU=http://www.CAcert.org, CN=CAcert Class 3 Root
        Validity
            Not Before: Mar 23 15:27:11 2024 GMT
            Not After : Mar 23 15:27:11 2026 GMT
        Subject: C=AU, ST=NSW, L=Sydney, O=CAcert Inc., CN=www.cacert.org
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
            RSA Public Key: (4096 bit)
                Modulus (4096 bit):
                    00:dc:2b:89:38:47:7a:09:af:bd:81:41:d9:7d:bc:
                    d6:62:79:77:e1:76:00:41:19:c1:a0:52:49:25:a8:
                    ab:be:41:61:12:79:97:99:1e:f1:01:c6:73:1d:dc:
                    f0:26:43:3e:53:e3:a2:9c:98:08:8c:bc:2d:18:40:
                    ef:92:1f:56:14:67:47:98:a6:8a:45:46:e0:6b:2f:
                    a7:9e:ef:03:3c:2b:c4:1b:62:02:1f:08:a9:92:92:
                    96:89:37:d0:86:99:d3:ad:86:ee:e3:cd:5d:ac:70:
                    35:91:98:73:80:9c:00:3d:8c:46:64:c0:c4:16:d5:
                    6a:7f:b0:6b:e8:7f:35:3c:13:6b:f3:9f:67:08:da:
                    55:d5:38:98:31:49:a5:e8:06:97:ab:6a:9b:5d:3e:
                    01:d6:56:ed:bb:cf:1d:b8:39:18:f9:e7:f1:63:8d:
```

También podremos generar un archivo con esta misma salida mediante el siguiente comando:

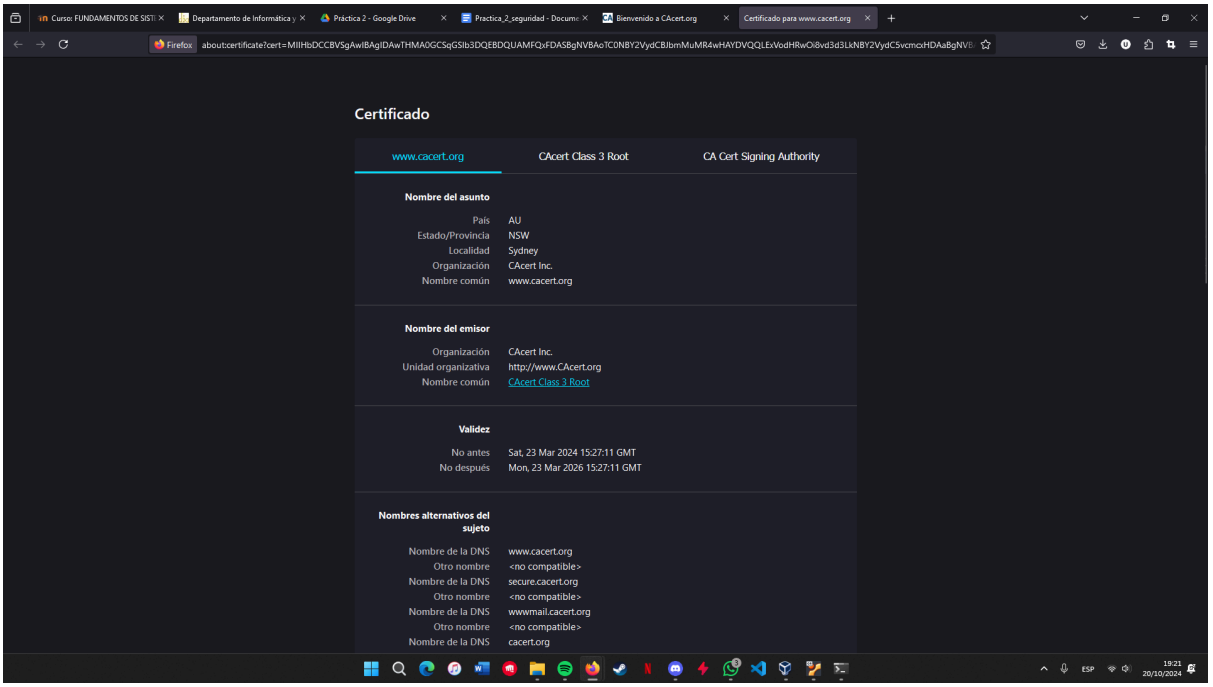
```
C:\Users\unaig>openssl s_client -connect www.cacert.org:443 | openssl x509 -out certificado.pem
Loading 'screen' into random state - done
depth=2 /O=Root CA/OU=http://www.cacert.org/CN=CA Cert Signing Authority/emailAddress=support@cacert.org
verify error:num=19:self signed certificate in certificate chain
verify return:0
read:errno=0
```

(Adjuntamos el archivo generado a la entrega)

Para verlo desde el navegador, en nuestro caso Mozilla, le daremos al candado y posteriormente a más información.



Y al darle a “Ver certificado” nos saldrá lo siguiente donde podremos ver el certificado de sitio:



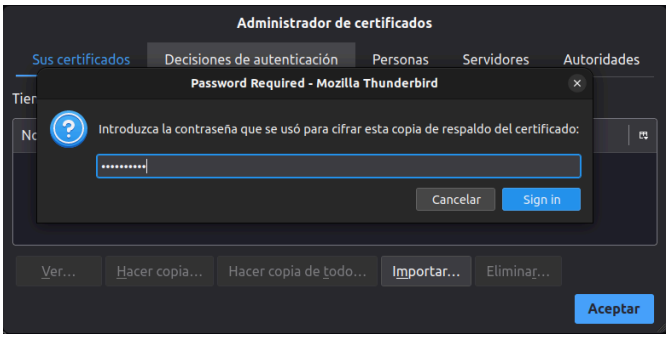
3. Firma y cifrado de mensajes de correo electrónico

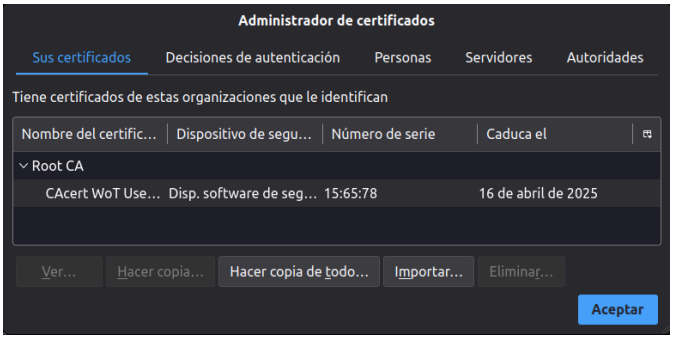
Instalar los certificados obtenidos en nuestra aplicación cliente de correo.
Enviar correos con las distintas funciones de seguridad (firmado y/o cifrado) al compañero de prácticas.
Comprobar en el lado receptor su autenticidad y obtener el mensaje claro si se recibe cifrado.
Para autenticar es necesaria la clave pública del firmante (remitente) que estará en un certificado dentro del almacén de certificados de otras personas. Para ello tenemos que haber obtenido y cargado el certificado del remitente del correo. Se procederá de manera similar a la instalación del certificado propio.
Usar un cliente de correo web para tratar de ver los correos firmados y/o cifrados que hayan llegado al buzón.

https://www.sslmarket.es/blog/firmamos-el-correo-certificados-s-mime-en-la-practica

Empezaremos con la importación de los certificados a los clientes de correo indicados. En nuestro caso, ambos usaremos Mozilla Thunderbird, pero Unai en Linux y Alberto en Windows.

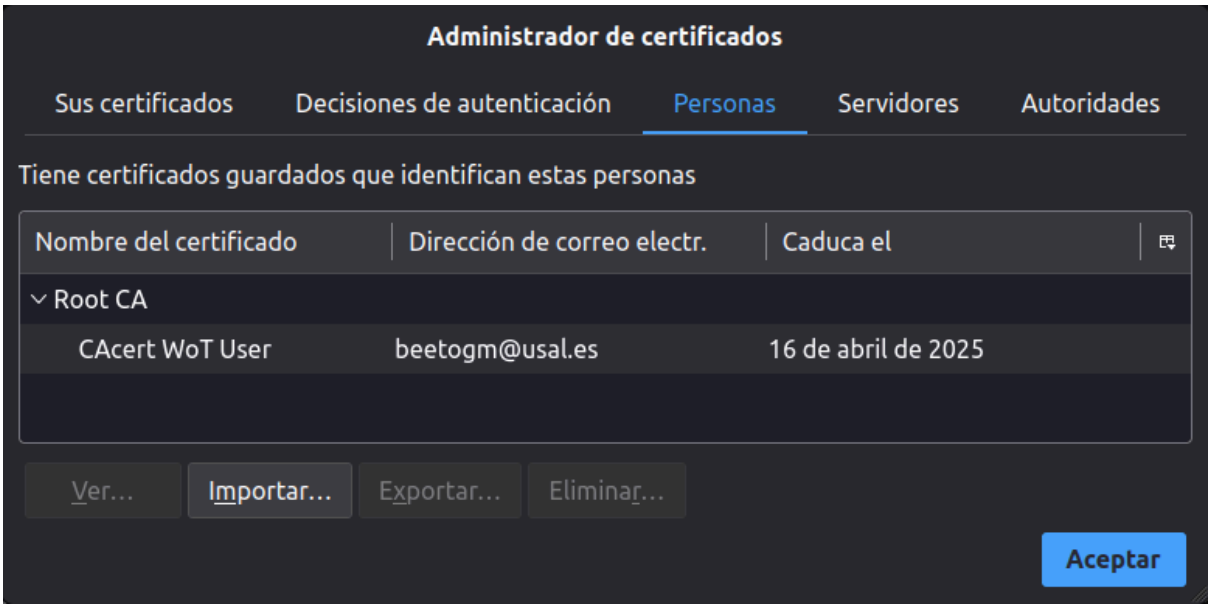
Primero importamos nuestro certificado personal en Thunderbird:





Aclarar que nos dio problemas al usar el certificado .p12 del apartado anterior, así que simplemente obtuvimos el mismo, pero en .pfx y de esa manera ya nos funcionó.

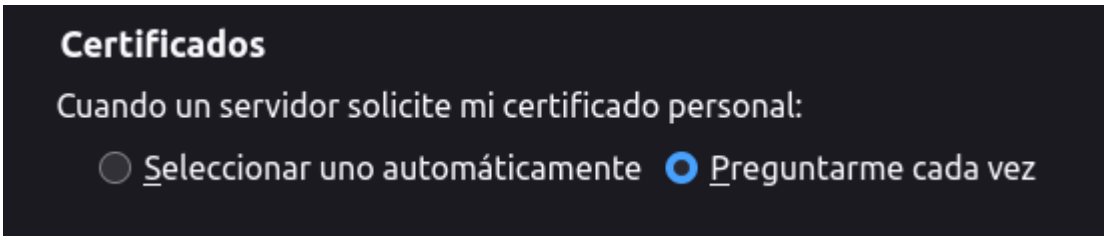
Una vez hecho esto, importamos cada uno el .crt del otro para verificar la autenticación de la firma.



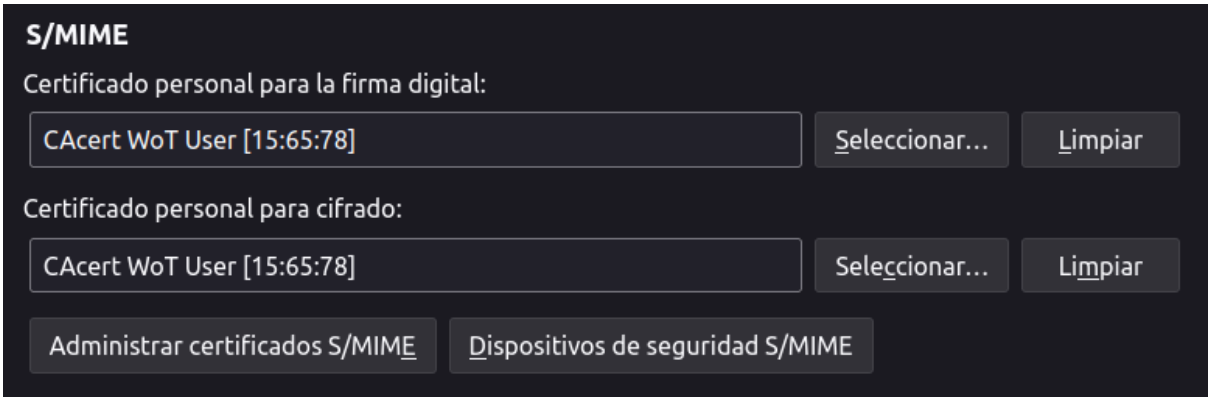
(Captura realizada por Unai)

Una vez hecho todo esto, se realizan unas configuraciones básicas.

En Ajustes > Privacidad y seguridad > Certificados, marcaremos la siguiente opción:

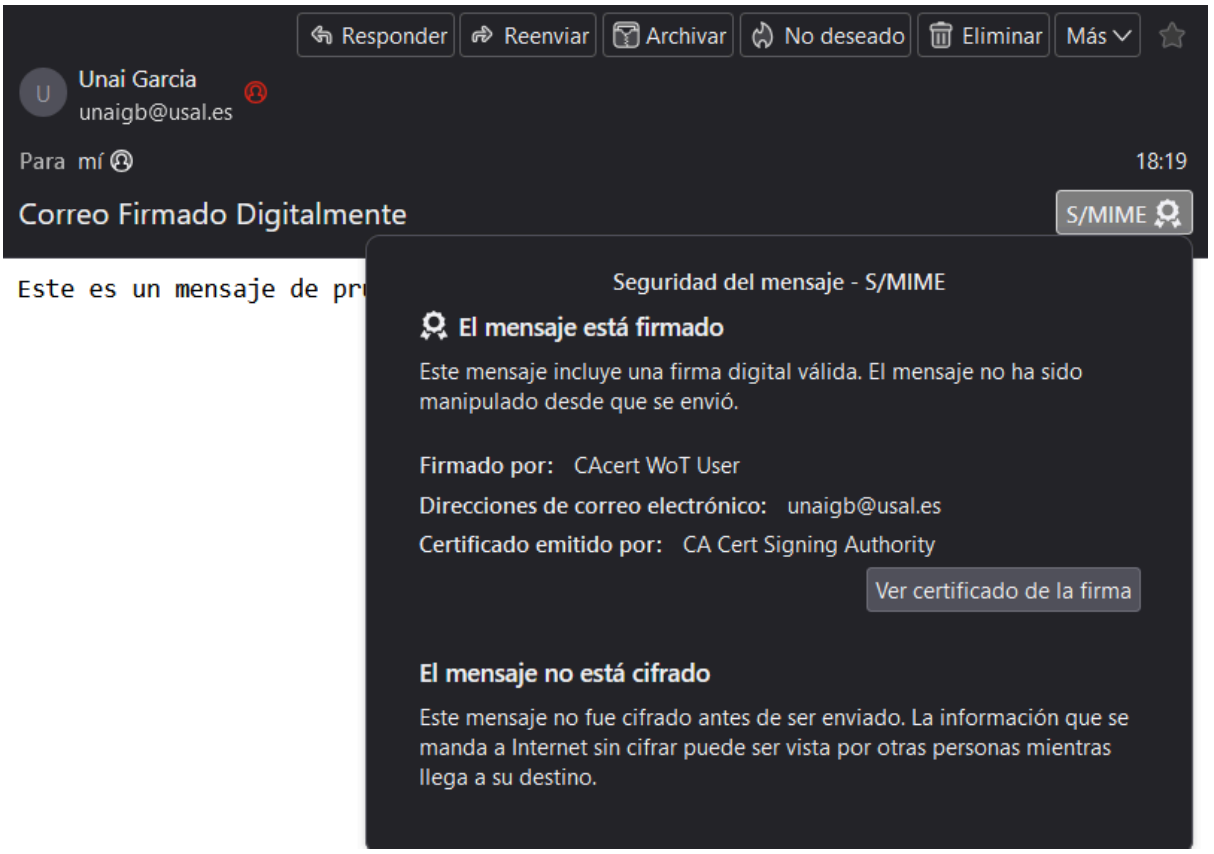


Y en las preferencias de la cuenta, Cifrado extremo a extremo > S/MIME seleccionaremos el certificado personal importado para su uso en la firma digital y en el cifrado.



Una vez tenemos todo hato hecho, podremos enviar los mensajes.

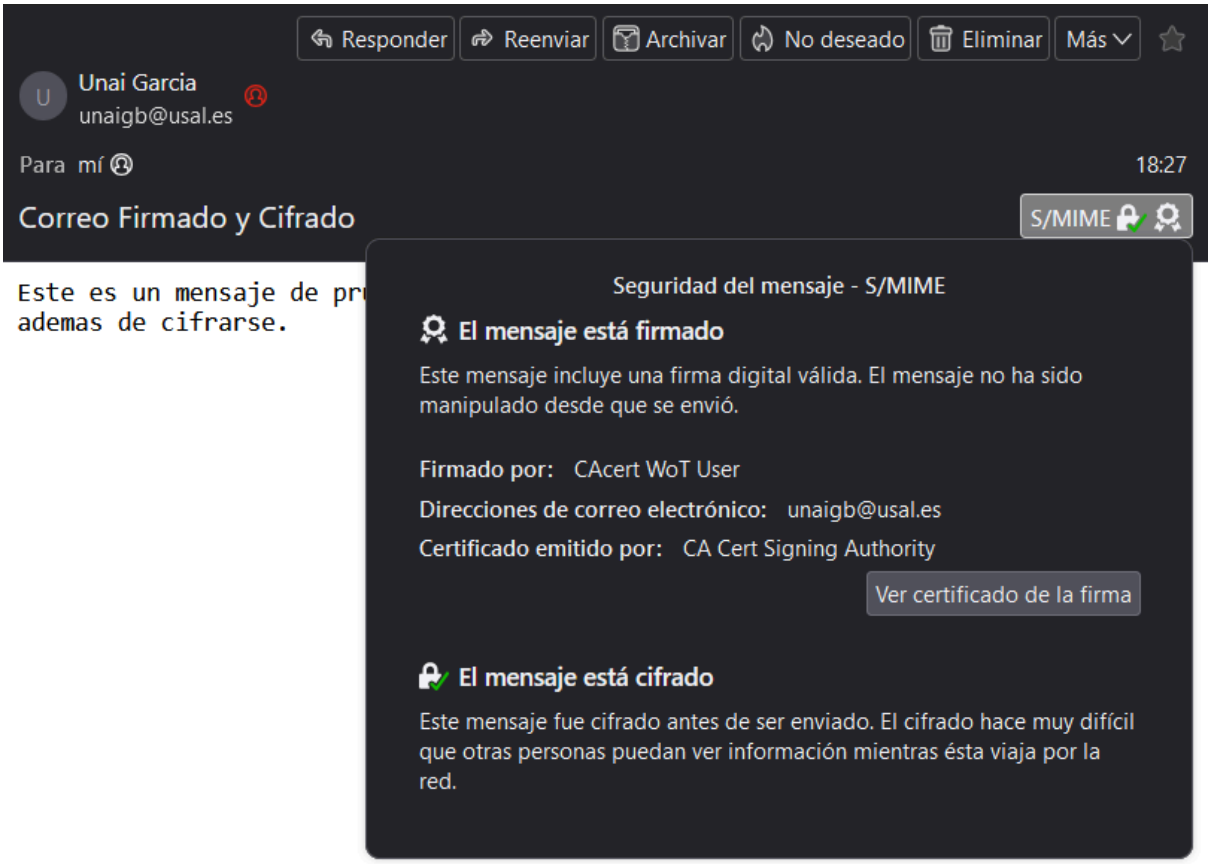
Mensaje firmado de Unai:



Mensaje cifrado de Unai:



Mensaje cifrado y firmado de Unai:

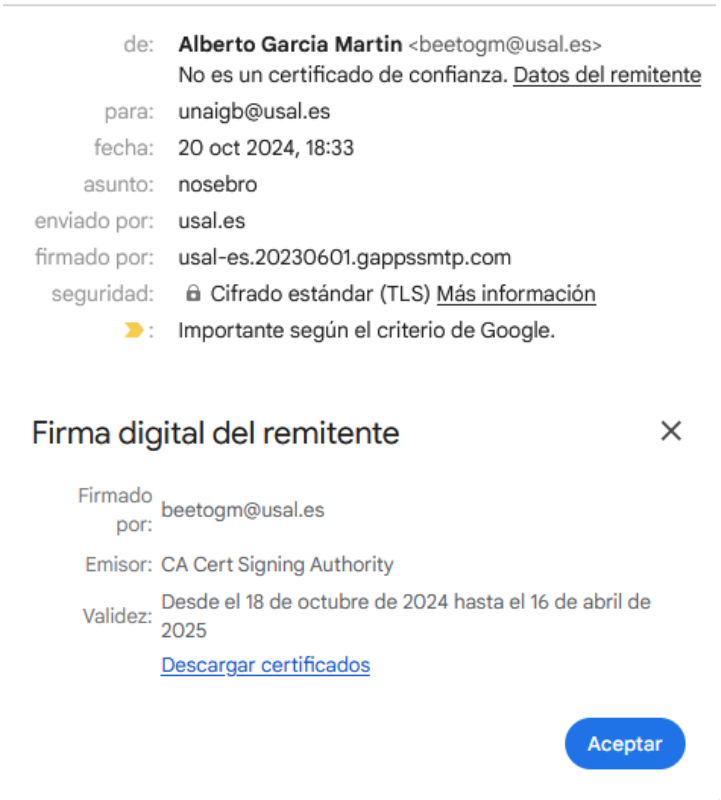


Mensaje cifrado y firmado de Alberto:



Como podemos comprobar, cuando se firma el mensaje se reconoce correctamente la firma, cuando se cifra se consigue leer claramente el mensaje y cuando se hacen las dos funciones de seguridad a la vez, se observa el mismo resultado, por lo que la configuración ha sido correcta.

Ahora bien, en el caso de los clientes web (en nuestro caso hemos comprobado en Gmail), hemos observado que la firma si que la muestra, aunque no sea una certificación de confianza.



Y en el caso del cifrado, no se suele trabajar tanto con ello, ya que en la nube no es tan seguro como en un dispositivo local, por lo que en el caso del mensaje cifrado obtenemos lo siguiente.

